

Third Party Risk Management (TPRM)

Risk Analysis, GRC & Fraud Intelligence System
SQL + Power BI | 1,000 Vendor Records

Why This Project Exists and What It Achieves

Fintech companies are only as strong as the vendors they trust. Yet most organizations have no structured, data driven way to manage third party exposure. Vendor decisions get made on gut feel, compliance reviews happen reactively, and fraud signals go undetected until money has already left the building. That is the problem this project was built to solve.

Using MySQL and Power BI across 1,000 simulated vendor records, I built a full TPRM system covering data quality assurance, weighted risk scoring, fraud detection, automated compliance reporting, and an executive dashboard.

What the Analysis Revealed

Nearly half the portfolio 48.1% fell into High or Critical risk tiers. More striking was that every single vendor category scored below the 60-point cybersecurity threshold. This was not an isolated problem. It was systemic. On the fraud side, 544 vendors were flagged for suspicious contract values, 9 showed round number invoice patterns consistent with fictitious billing, and 6 vendors were registered on the same date and a known signal for synthetic vendor network creation.

These are the decisions this analysis support

1. **Procurement:** Vendors are objectively scored and tiered, removing gut feel from contract renewal and termination decisions
2. **Finance:** 544 high value flags and 9 invoice anomalies create a review list before the next payment cycle, preventing losses rather than recovering them
3. **Leadership:** Portfolio distribution data gives the CRO a clear answer on whether third-party exposure sits within the organization's risk appetite
4. **Compliance:** Automated alerts mean the team can respond to a CBN, FCA, or PCI-DSS regulator immediately with accurate, structured evidence
5. **Onboarding:** Anomaly detection creates clear decision points before vendors access any payment systems or customer data

The Bigger Picture

Third party risk is not one time exercise. Vendors change, contracts renew, and new threats emerge. This system is built to run continuously and the organization is always working from current data, not last quarter's snapshot. In an industry where a single vendor breach can expose millions of payment records and a missed compliance deadline can trigger regulatory action. It is a core operational requirement.

Risk Level	Vendor Count	% of Portfolio	Required Action
Critical	260	26%	Immediate Escalation
High	221	22.1%	Enhance due diligence
Medium	257	25.7%	Standard Monitoring
Low	262	26.2%	Routine Review

48.1% of vendors fall in the High or Critical risk tiers, requiring active monitoring or immediate remediation.

1. Project Overview

This project builds a SQL based vendor risk management system modeled on the third party risk environment of a fintech or digital payments company. It covers the full TPRM lifecycle across 1,000 simulated vendor records: data quality assurance, weighted risk scoring, industry criticality analysis, fraud and anomaly detection, automated compliance reporting via stored procedures, and an executive Power BI dashboard for stakeholder reporting.

Fintech companies outsource critical functions payment processing, KYC/KYB identity verification, cloud infrastructure, and regulatory compliance to external vendors. Each relationship introduces operational, cybersecurity, financial, and regulatory risk. This framework provides the analytical infrastructure to measure, monitor, and act on that exposure systematically.

The regulatory references in this project are drawn from both Nigerian and international fintech practice, making the framework applicable for roles in Nigeria and globally.

2. Data Quality Assurance

In a regulated fintech, poor data quality in vendor records creates direct compliance risk. A single inaccurate compliance score or missing audit date can become a direct finding during an FCA, CBN, or PCI-DSS examination. Six checks were performed before any risk scoring or analysis:

Check Performed	Finding and Fintech Application
Orphan Audit Record	Audit records with no matching vendor detected indicates deregistered vendors still being assessed, a vendor offboarding compliance gap
Invalid Score Ranges	Scores outside 0-100 detected distort weighted risk calculations and produce incorrect regulatory reports
Null Critical Fields	Missing compliance scores and audit dates flagged in a regulated fintech, missing scores place a vendor on automatic approval hold

Critical Records	47 duplicates found inflate risk exposure metrics and cause double counting in executive dashboards
Category Standardization	Inconsistent labels unified (IT / it / info tech to Information Technology) required for accurate industry level segmentation
Future Audit Date	Future dated records identified create false compliance in audit freshness reports; a direct finding in regulatory examinations

3. Risk Analysis

a. Weighted Risk Scoring Model

A Weighted Risk Index was developed combining three scoring dimensions, weighted to reflect fintech risk priorities:

$$\text{Weighted Risk Index} = (\text{Cyber} \times 0.50) + (\text{Financial} \times 0.30) + (\text{Compliance} \times 0.20)$$

Cybersecurity is weighted highest at 50% because a vendor data breach in fintech exposes customer payment records and triggers mandatory regulatory notifications under GDPR, CBN Incident Reporting requirements, and the NDPA. Financial stability is weighted at 30% to reflect vendor insolvency risk mid-contract. Compliance at 20% covers KYC and AML adherence.

Vendor Tiers	
Elite Partner (WRI > 75)	Top performers from actual results: Einti (Logistics, 94.7), Buzzdog (Cloud Provider, 94.0), Edgeblab (Legal, 91.0), Eimbee (Legal, 90.2), Rhyloo (Financial, 89.8). Suitable for high value contracts and preferred vendor designation.
Standard (WRI 50-75)	Acceptable risk profile standard vendor relationships with routine annual monitoring and review.
High-Exposure (WRI < 50)	Significant risk in one or more dimensions escalate for remediation; not suitable for payment or data-processing roles.

An important finding from the weighted scoring results: despite all five vendor categories averaging below 60 on cybersecurity at the portfolio level, individual vendors within those categories still score as Elite Partners when their financial and compliance scores are strong. Category level risk does not always predict individual vendor performance, and the weighted model captures this distinction accurately.

b. Industry Criticality Analysis

Vendor categories were ranked by average cybersecurity score to identify where portfolio risk is concentrated. The results revealed a critical finding:

Category	Total Vendor	Average Cyber score	Priority Flag
Logistics	190	49.47	IMMEDIATE ATTENTION
Legal	186	50.47	IMMEDIATE ATTENTION
Cloud Provider	215	50.71	IMMEDIATE ATTENTION
IT Services	204	51.88	IMMEDIATE ATTENTION
Financial	206	51.88	IMMEDIATE ATTENTION

All five vendor categories scored below the 60-point threshold and were flagged as Immediate Attention. This means the organization faces broad, systemic cybersecurity exposure across the entire vendor portfolio not isolated pockets of risk. No category reached Monitor or Stable status. This finding significantly escalates the overall risk assessment and demands a portfolio-wide remediation program rather than targeted category level intervention

c. Audit Freshness and Compliance Cadence

Vendors with audit dates older than 300 days are flagged as Expiring Soon. Those beyond 365 days are flagged as Expired. PCI-DSS requires annual vendor assessments for any vendor in the cardholder data environment. An expired vendor audit is a direct compliance finding in an FCA or CBN examination and can result in enforcement action or licence review.

d. Remediation Tracker

High risk vendors were mapped to specific corrective actions based on their individual score profiles. The actual query results produced three action tiers:

Recommended Action	Vendors Identified
Initiate Technical Security Audit (cyber score < 40)	Zazio, Innotype, Skippad, Blogtag, Feednation, Voonix cyber posture critically weak; restrict access to payment systems pending full security audit
Request 3 Year Audited Financials (financial score < 40)	Realblab financial distress risk; assess solvency and business continuity before next contract renewal
Quarterly Performance Review (all other High-risk vendors)	Brainsphere, Ooba, Quimba, Layo, Twimm, Skyba, Rooxo, Cogilith and others High overall classification; maintain enhanced monitoring cadence

4. Fraud Intelligence and Anomaly Detection

Five behavioural patterns were analyzed using SQL anomaly detection techniques, each mapped to a documented fraud typology in the fintech and digital payments industry

Detection	Findings and Fraud Typology
High contract values (> \$900,000)	544 vendors flagged Muxo IT Services (\$1,994,249), Skinte Legal (\$1,823,346), Midel Financial (\$1,708,563), Brainsphere IT Services (\$1,679,950). Typology: payment processor overbilling vendors inflate API call or transaction volume data to increase billable amounts.
Ghost vendor check (missing country)	0 cases detected strong onboarding data completeness. Missing jurisdiction data in fintech triggers AML screening failure and blocks KYB completion under FATF and GIABA guidance.
Onboarding spike (same-date bulk)	1 anomaly detected 6 vendors registered on 1 January 2023. Typology: synthetic vendor network creation; coordinated registration to route fraudulent transactions through seemingly legitimate third party relationships.
Risk vs. incident mismatch	0 mismatches detected confirms the risk scoring model is calibrated correctly and not being manipulated to reduce monitoring scrutiny on high incident vendors.
Round number contracts (value % 100 = 0)	9 vendors flagged Realcube (\$1,882,500), Aimbu (\$1,801,700), Buzzdog (\$1,499,600), Yakidoo (\$1,211,500), Linktype (\$1,168,500). Typology: fictitious invoicing and kickback schemes.

5. Store Procedures

Three parameterized stored procedures were developed to operationalize the risk framework enabling consistent, schedulable reporting without manual query execution each time:

Procedure	Purpose and Fintech Application
Get_Industry_Risk_Report (input_industry)	Filters vendor risk by category with automated consultant recommendations. Called before quarterly vendor reviews for example, pulling all Cloud Provider vendors ranked by cyber score for the CISO review pack.

Get_Top_Vendors (min_score)	Returns all vendors meeting a minimum threshold across all three dimensions simultaneously. Identifies Elite Partners eligible for expanded contract scope or preferred vendor designation.
Get_Compliance_Alerts ()	Flags all vendors with compliance scores below 60 as Critical Non Compliance or Moderate Risk. Designed to run on a weekly schedule with automated alerts distributed to the Compliance and Legal teams.

6. Power BI Executive Dashboard

An executive reporting dashboard was built in Power BI to give risk teams and stakeholders a single view summary of the full vendor portfolio. The dashboard covers portfolio risk distribution, vendor tier classification, industry criticality analysis using the actual query results, fraud anomaly detection counts, data quality check outcomes, and regulatory framework coverage split by Nigerian and global obligations.

Every visual in the dashboard maps directly to a SQL query in the project, making it straightforward to trace any dashboard figure back to its source query and result set.

7. Regulatory Alignment

This framework maps to specific compliance obligations in both the Nigerian and global fintech regulatory environment:

Framework	Scope and Application
CBN Risk Based Cybersecurity Framework	Nigeria: Weighted risk scoring provides the quantitative basis for vendor cyber assessments required for CBN regulated financial institutions
FATF / GIABA AML and KYB	Nigeria and Global: Ghost vendor detection supports beneficial ownership verification required under anti money laundering guidance
Nigeria Data Protection Act 2023 (NDPA)	Nigeria: IT Services and Cloud Provider vendors with data access flagged for enhanced data processor risk assessments
PCI-DSS	Global audit freshness queries enforce annual vendor assessments for any vendor in the cardholder data environment

GDPR	Global enhanced due diligence for vendors handling EU personal data; supports data processor risk documentation
------	---

8. Findings and Recommendations

48.1% of vendors are High or Critical risk	Initiate a formal remediation program assign a named risk owner, remediation deadline, and minimum acceptable score to each High and Critical vendor
All 5 vendor categories flagged Immediate Attention with avg cyber scores between 49 and 52	Launch a portfolio-wide cybersecurity improvement program engage all vendors with minimum cyber score requirements at next contract renewal
Remediation tracker identifies 3 action tiers across named vendors	Execute immediately: security audits for Zazio, Innotype, Skippad and others with cyber score below 40; financial review for Realblab; quarterly reviews for remaining High risk vendors
544 high value contracts and 9 round number vendors flagged	Engage internal audit for a sample invoice review cross validate against service delivery records before next renewal cycle
6 vendors onboarding spike on 1 January 2023	Trigger KYB re verification for this cohort implement an automated rule flagging bulk same date onboarding events for enhanced due diligence
0 ghost vendors and 0 risk incident mismatches	Positive indicators onboarding data controls and risk model calibration are functioning correctly; maintain current standards